Projet RGPD : mise en conformité d'EfreiShop

Étude de cas réalisée dans le cadre d'un Master GRC. EfreiShop SAS, ses collaborateurs, ses prestataires et ses chiffres sont fictifs ; les références réglementaires sont réelles.

1. Contexte

EfreiShop est une PME française qui vend des luminaires et des objets de décoration sur son site internet et dans deux boutiques. Son siège est situé à Villejuif (Val-de-Marne). L'entreprise emploie 85 salariés et gère 120 000 comptes clients et 300 000 abonnés à sa newsletter. Elle s'appuie sur cinq sous-traitants : Hélios (CRM), PayNova (paiement), LogiFlux (livraison), PaieExpert (paie) et NuageSûr (hébergement).

En 2026, EfreiShop lance EfreiShop+, un programme de fidélité qui analyse les achats en ligne et en boutique pour proposer des offres personnalisées. Un audit réalisé en septembre 2026 relève 11 écarts au RGPD, dont 5 graves : pas de registre des traitements, pas de DPO, un contrat de sous-traitance incomplet, aucune analyse d'impact pour EfreiShop+ et aucune procédure en cas de violation de données. La direction demande une mise en conformité rapide et un suivi chiffré.

2. Mission

En tant que chargé de mission conformité RGPD, aux côtés de la DPO nouvellement désignée, il faut corriger les écarts relevés par l'audit, mettre en place les outils de pilotage exigés par le règlement et proposer un plan d'actions priorisé à présenter à la direction. Les informations disponibles sont le rapport d'audit, les entretiens avec les responsables (direction, DSI, marketing, RH, service client) et la liste des contrats prestataires.

3. Travail demandé

Le livrable est un classeur Excel de suivi. Chaque tâche correspond à un onglet.

1. **Registre des traitements (onglet Registre) :** recenser les traitements de l'entreprise avec leur finalité, leur base légale, les données et personnes concernées, les destinataires, les durées de conservation et indiquer ceux qui nécessitent une analyse d'impact (art. 30).
2. **Analyse des écarts (onglet Écarts) :** reprendre les constats de l'audit, les rattacher à l'article concerné, évaluer leur gravité et suivre leur correction.
3. **Registre des violations (onglet Violations) :** documenter chaque violation de données, évaluer le risque pour les personnes, décider de la notification à la CNIL et calculer automatiquement l'échéance de 72 heures (art. 33 et 34).
4. **Demandes de droits (onglet Droits) :** suivre les demandes d'accès, d'effacement, d'opposition ou de portabilité et calculer le délai de réponse d'un mois, prolongeable de deux mois (art. 12 à 22).
5. **Sous-traitants (onglet Sous-traitants) :** vérifier pour chaque prestataire la présence des clauses obligatoires de l'article 28.3 et suivre la signature des accords.
6. **Analyse d'impact (onglet AIPD EfreiShop+) :** justifier l'obligation d'AIPD avec les critères du CEPD, évaluer les risques (gravité × vraisemblance) avant et après mesures et définir les mesures complémentaires (art. 35).
7. **Plan d'actions (onglet Plan actions) :** traduire les écarts en actions avec responsable, échéance et priorité.
8. **Synthèse (onglet Synthèse) :** consolider automatiquement les indicateurs clés : écarts corrigés, violations notifiées, délais respectés, accords signés et avancement du plan.

4. Hypothèses

- EfreiShop est responsable de traitement ; ses prestataires sont des sous-traitants au sens de l'article 28.
- Le programme EfreiShop+ réalise un suivi régulier et à grande échelle des clients : la désignation d'un DPO est obligatoire (art. 37).
- L'autorité de contrôle compétente est la CNIL.
- Les dates de l'étude vont jusqu'à novembre 2026 ; les accords de sous-traitance manquants doivent être signés avant le 30 novembre 2026.
- Chaque correction doit pouvoir être justifiée par une preuve (document, contrat, capture d'écran).